

Vendor Security and Student Data Privacy Review Packet

Pre-procurement risk review for K-12 software, cloud, AI-enabled tools, and service providers

OWNER
Technology + Procurement
+ Privacy + Legal

DISTRICT
Ardent ISD

REVIEW CYCLE
Annual + after major
incident

POLICY CROSS-REFERENCE

CQB

FL

procurement
procedures

Training Sample - Customize Before Use. This document is an instructional artifact for Ardent ISD. It should be aligned to current board policy, administrative procedures, cyber-insurance requirements, records-retention requirements, and advice of district legal counsel before operational use. Legal and reporting requirements can change.

Purpose

Ardent ISD uses this packet before a product is approved to receive district student, employee, authentication, financial, or operational data. The packet is modeled on the leadership intent of CoSN's K-12CVAT: vendor review should be a **repeatable procurement risk process**, not an afterthought after implementation.

Part 1 - Intake

Question	Response
Product/service	
Requesting campus/department	
Instructional/operational purpose	
Intended users	☐ Students ☐ Staff ☐ Parents ☐ Public
Student age range	
Data owner/steward	
Contract term / renewal date	
Cost / funding source	
Integrations requested	☐ SSO ☐ SIS ☐ LMS ☐ Rostering ☐ API ☐ Other

Question	Response
AI-enabled functionality	☐ No ☐ Yes - describe

Part 2 - Data Map

What will the vendor receive or create?

- ☐ Student name/contact information
- ☐ District student identifier
- ☐ Grades/assessment data
- ☐ Special education/disability information
- ☐ Health/medical information
- ☐ Discipline/behavior information
- ☐ Student work, messages, audio, images, or video
- ☐ Search/activity telemetry or device identifiers
- ☐ Geolocation
- ☐ Employee personnel information
- ☐ SSN/government ID/financial information
- ☐ District credentials, tokens, directory/group information
- ☐ Security logs/configuration data
- ☐ No personally identifiable/protected data

Data minimization question: What fields can be removed while still meeting the educational/business purpose?

Part 3 - Privacy and Legal Review

Topic	Required vendor answer / reviewer test
FERPA	What education-record PII is received? Under what exception/consent model? Is the provider under district control regarding use/maintenance when relying on the school-official exception?
Texas Student Privacy Act (TEC Chapter 32)	Is the product an operator of a school-purpose online service? Does it maintain reasonable security? How are covered information, disclosure, third parties, deletion, and school-purpose limitations handled?
COPPA	If children under 13 use the service, does vendor rely on school consent? Is data used solely for the school's educational purpose and not a separate commercial purpose?
Parent transparency	What privacy notice can the district provide families? Is data collection understandable?
Data ownership/control	Does Ardent retain ownership/control of district data? Can vendor assert rights inconsistent with district purpose?
Sale/advertising	Is student data sold, used for targeted advertising, or used to build unrelated commercial profiles?
Model/AI training	

Topic	Required vendor answer / reviewer test
	Is district/student data used to train shared/general models? Can that use be disabled contractually and technically?
Deletion	Can Ardent request deletion at contract end and verify completion? Texas law includes deletion requirements for covered information in defined circumstances.

Part 4 - Cybersecurity Review

Baseline Security Questions

1. Does the vendor maintain a documented security program and named security owner?
2. Does the vendor support MFA for administrative/privileged accounts?
3. Is data encrypted in transit and at rest? What happens to encryption keys?
4. How are privileged support accounts approved, logged, and reviewed?
5. Are production and development/test data separated?
6. How frequently are vulnerabilities identified and remediated?
7. Does the vendor conduct independent security assessments (e.g., SOC 2 or equivalent) and provide appropriate evidence under NDA?
8. How are subprocessors identified and controlled?
9. What are backup, disaster recovery, RTO, and RPO commitments?
10. What log/audit evidence will be available to Ardent after an incident?
11. What is the vendor's incident-notification commitment to Ardent (hours, not "without undue delay" alone)?
12. How does the vendor support data export, return, deletion, and account termination?

Part 5 - Incident and Contract Requirements

Ardent ISD prefers contract/DPA language that addresses:

- prompt security-incident notice with a defined time period;
- facts required in each update: discovery time, affected systems/data, record count, containment, known access/exfiltration, subprocessors, law enforcement;
- cooperation with Ardent's legal/regulatory reporting obligations;
- preservation and provision of relevant logs/evidence;
- notification approval/coordination when district data is involved;
- data return/deletion and written certification at termination;
- limits on secondary use, sale, advertising, and non-school-purpose use;
- subprocessor obligations no weaker than the primary agreement;
- cyber insurance where appropriate to risk;
- breach costs/indemnity subject to district counsel and procurement rules;
- right to suspend integration/access during an active incident.

Part 6 - AI-Enabled Tool Questions

If the product includes generative AI, machine learning, automated recommendations, transcription, summarization, or other AI features:

1. Exactly what prompts, files, chats, student work, telemetry, and metadata are retained?
2. Are inputs/outputs used to train shared or future models?
3. Can training/secondary use be contractually and technically disabled?
4. Are prompts/outputs visible to vendor human reviewers?
5. How long are prompts/outputs retained, and can Ardent delete them?
6. What safeguards address minors, harmful content, bias, hallucinations, and inappropriate automated decisions?
7. Can Ardent disable AI features independently from the core service?
8. Are subprocessors/model providers disclosed?
9. What incident-notification obligations apply to the AI provider/subprocessor?

Ardent AI security guardrail: Do not upload real student data, employee data, credentials, security configurations, incident reports, vulnerability findings, or vendor-confidential agreements into a public generative AI service for the purpose of completing this review.

Part 7 - Reviewer Scorecard

Domain	Low risk / acceptable	Needs mitigation	Escalate/reject	Notes
Data sensitivity/minimization	☐	☐	☐	
FERPA/Texas privacy	☐	☐	☐	
COPPA/child privacy	☐	☐	☐	
Security controls	☐	☐	☐	
Incident response	☐	☐	☐	
Subprocessors/data location	☐	☐	☐	
Deletion/exit	☐	☐	☐	
AI/model use	☐	☐	☐	
Contract terms	☐	☐	☐	

Decision: ☐ Approve ☐ Approve with conditions ☐ Pilot with limited data ☐ Escalate to Legal/Security ☐ Reject

Conditions / compensating controls: _____

Re-review date: _____

Sample Mini-Review - SummitLearn Assessment Platform

Purpose: formative assessment and teacher feedback; grades 6-8.

Requested data: student name, district ID, class/teacher, responses, scores.

Initial finding: Vendor supports SSO and encryption, but its standard terms allow broad service-improvement use and provide only “commercially reasonable” incident notice with no time commitment.

Ardent decision: Approve with conditions - execute district DPA; limit data fields; prohibit use for targeted advertising/general model training; require incident notice within contractually defined hours; require annual subprocessor list; verify deletion workflow before production launch.

References

- CoSN - K-12 Community Vendor Assessment Tool (K-12CVAT)
- U.S. Department of Education - Model Terms of Service for Online Educational Services
- U.S. Department of Education - Data Security: K-12 and Higher Education
- Texas Education Code Chapter 32 - Student Information Protection
- Federal Trade Commission - COPPA FAQ: COPPA and Schools
- TASB - School Cybersecurity: Texas Requirements